

TP : DEPLOIEMENT ET AUDIT DE WINDOWS LAPS

Sommaire du Projet

- I. Introduction & Concepts Clés
- II. Architecture du Lab & Prérequis
- III. Phase 1 : Préparation de l'Active Directory (PowerShell)
- IV. Phase 2 : Configuration de la GPO Moderne
- V. Phase 3 : Vérification et Exploitation
- VI. Mission SOC 1 : Audit des accès (Event ID 4662)
- VII. Mission SOC 2 : Test de Résilience & Désynchronisation

I. Introduction & Concepts Clés

Depuis 2023, Microsoft a intégré **Windows LAPS** directement dans le noyau du système d'exploitation. Il n'est plus nécessaire d'installer un agent (.msi). Cette version native offre des fonctionnalités avancées : chiffrement des mots de passe dans l'AD, gestion via Microsoft Entra (Azure) et surtout, une intégration parfaite avec l'Observateur d'événements.

Objectif du TP : Sécuriser les comptes administrateurs locaux et mettre en place une traçabilité (Audit) pour savoir qui consulte ces secrets.

II. Architecture du Lab & Prérequis

Équipement	Rôle / Version	Configuration requise
Serveur-AD	Windows Server 2022/2025	Rôle AD DS installé. PowerShell 5.1+.

Client- W10/11	Win 10 (22H2+) / Win 11	Joint au domaine. Mises à jour d'avril 2023 installées.
---------------------------	-------------------------	---

III. Phase 1 : Préparation de l'Active Directory (PowerShell)

Le schéma de l'Active Directory doit être modifié pour accepter les nouveaux attributs de Windows LAPS (différents de l'ancienne version Legacy).

1.1 Extension du Schéma

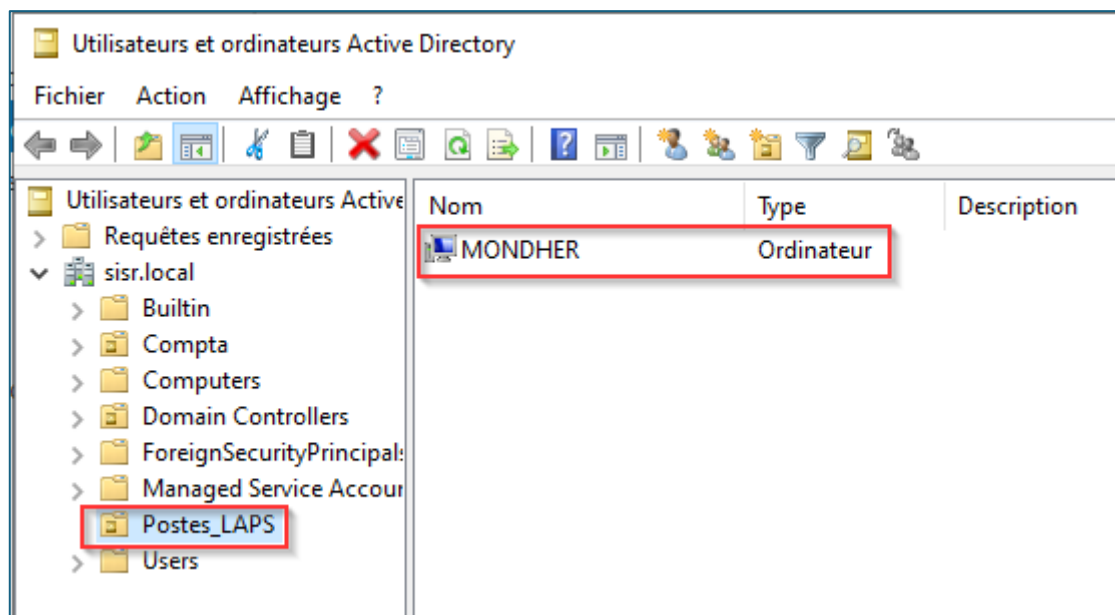
Sur le contrôleur de domaine, exécutez la commande suivante :

```
Update-LapsADSchema
```

Explication : Cette commande ajoute les droits nécessaires pour que l'AD puisse stocker le mot de passe de manière chiffrée.

1.2 Permissions de l'OU

Créez une OU « Postes_LAPS » dans la racine du domaine `sisr.local`. Puis déplacer l'ordinateur lié au domaine dans cette OU.



Déploiement et audit de Windows LAPS

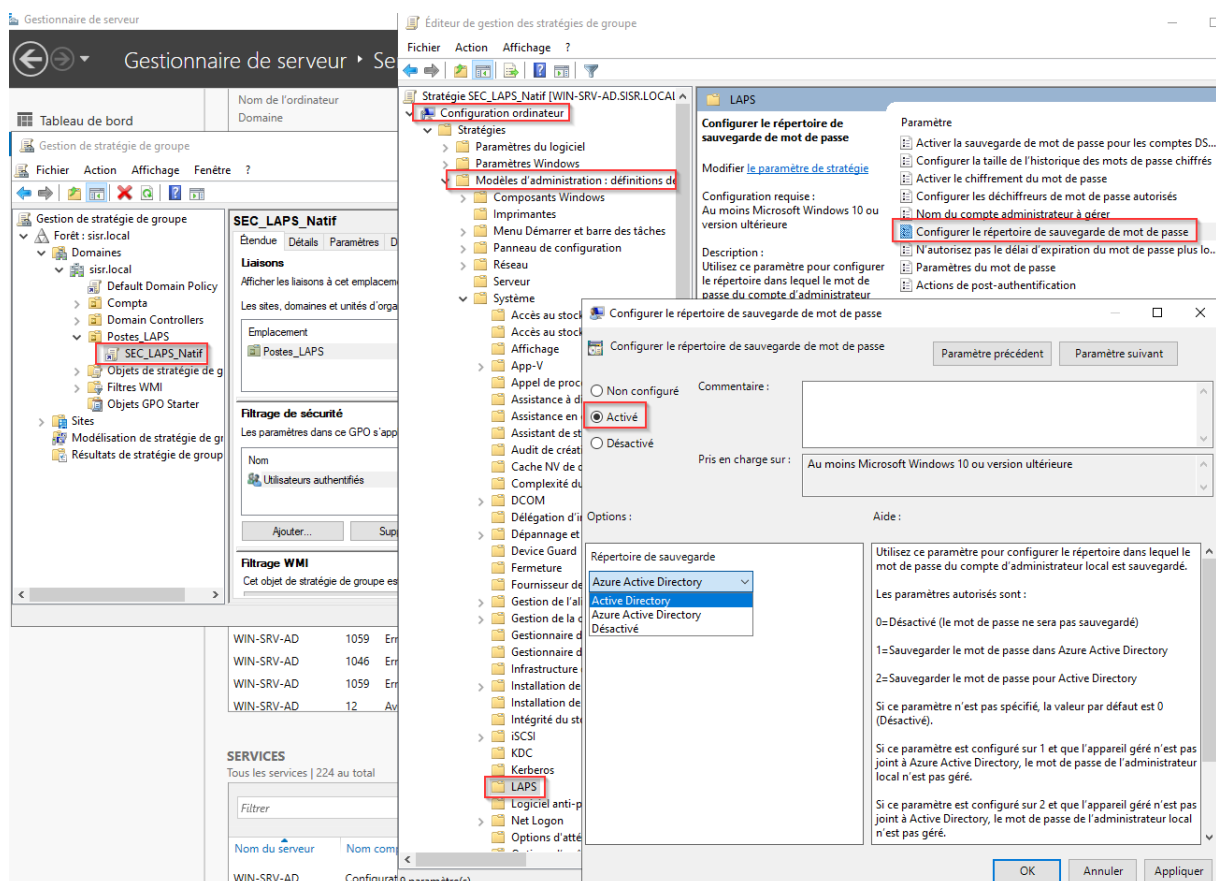
Les ordinateurs doivent avoir le droit d'écrire leur propre mot de passe, mais les utilisateurs standards ne doivent pas pouvoir le lire.

```
# Remplacez par le chemin de votre OU
Set-LapsADComputerSelfPermission -Identity
"OU=Postes_LAPS,DC=sisir,DC=local"
```

IV. Phase 2 : Configuration de la GPO Moderne

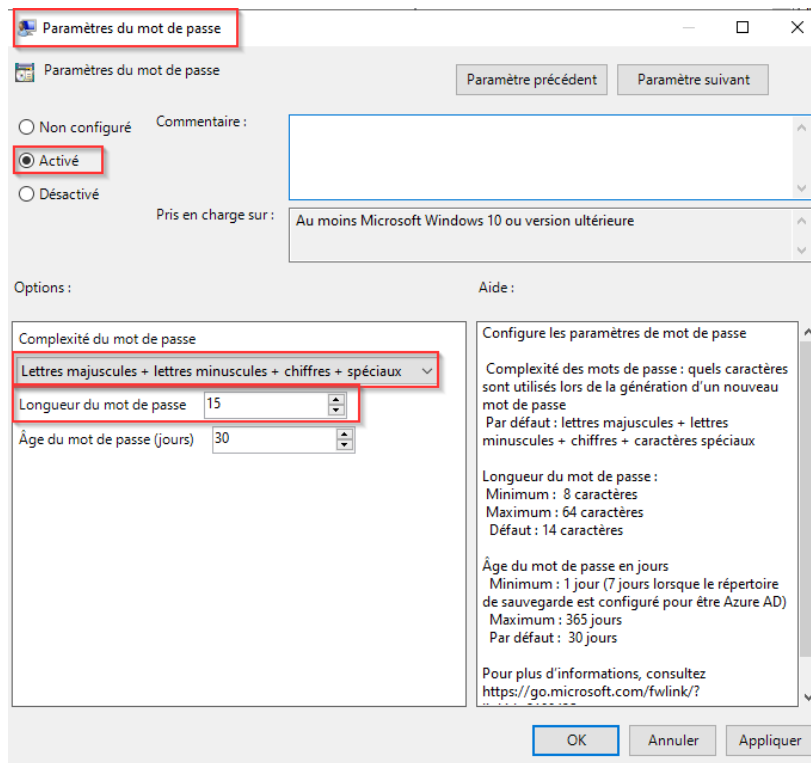
Le chemin des stratégies a changé. Il se trouve désormais dans les composants système de Windows.

1. Créez une GPO nommée **"SEC_LAPS_Natif"** sur l'OU « Postes_LAPS ».
2. Allez dans : Configuration ordinateur > Stratégies > Modèles d'administration > Système > LAPS.



3. Activez **"Configurer le répertoire de sauvegarde des mots de passe"** et choisissez **Active Directory**.

4. Activez "**Paramètres de mot de passe**" : configurez 15 caractères et incluez les symboles.



V. Phase 3 : Vérification et Exploitation

Sur le poste client, ouvrez l'invite de commande en mode administrateur et forcez la mise à jour : `gpupdate /force`.

```
Administrateur : Invite de commandes
Microsoft Windows [version 10.0.26200.8037]
(c) Microsoft Corporation. Tous droits réservés.

C:\Windows\System32>gpupdate /force
Mise à jour de la stratégie...

La mise à jour de la stratégie d'ordinateur s'est terminée sans erreur.
La mise à jour de la stratégie utilisateur s'est terminée sans erreur.

C:\Windows\System32>
```

Lecture du mot de passe (Méthode Admin)

```
# À exécuter sur le serveur  
Get-LapsADPassword -Identity "NOM_DU_PC"
```

```
PS C:\Users\Administrateur> Get-LapsADPassword -Identity MONDHER  
  
ComputerName      : MONDHER  
DistinguishedName : CN=MONDHER,OU=Postes_LAPS,DC=sisr,DC=local  
Account           : Administrateur  
Password           : System.Security.SecureString  
PasswordUpdateTime : 14/04/2026 21:25:49  
ExpirationTimestamp : 14/05/2026 21:25:49  
Source             : EncryptedPassword  
DecryptionStatus   : Success  
AuthorizedDecryptor : SISR\Admins du domaine
```

Attention! Si vous regardez la ligne Password, il est écrit *System.Security.SecureString* au lieu de vous donner le vrai mot de passe. Ce n'est pas un bug, c'est une fonctionnalité de sécurité très puissante de PowerShell.

Puisque le nouveau LAPS chiffre les mots de passe dans l'Active Directory (regardez la ligne Source : *EncryptedPassword*), PowerShell refuse de l'afficher en clair sur votre écran par défaut. Il le garde "masqué" en mémoire pour éviter que quelqu'un qui passe derrière votre dos ne le lise par-dessus votre épaule.

Pour dire à PowerShell : "C'est bon, je suis seul et j'assume le fait de l'afficher en clair", vous devez rajouter le paramètre *-AsPlainText* à la fin de votre commande.

```
Get-LapsADPassword -Identity "NOM_DU_PC" -AsPlainText
```

```
PS C:\Users\Administrateur> Get-LapsADPassword -Identity MONDHER -AsPlainText  
  
ComputerName      : MONDHER  
DistinguishedName : CN=MONDHER,OU=Postes_LAPS,DC=sisr,DC=local  
Account           : Administrateur  
Password           : kG-[16R2,W!#}7p  
PasswordUpdateTime : 14/04/2026 21:25:49  
ExpirationTimestamp : 14/05/2026 21:25:49  
Source             : EncryptedPassword  
DecryptionStatus   : Success  
AuthorizedDecryptor : SISR\Admins du domaine
```

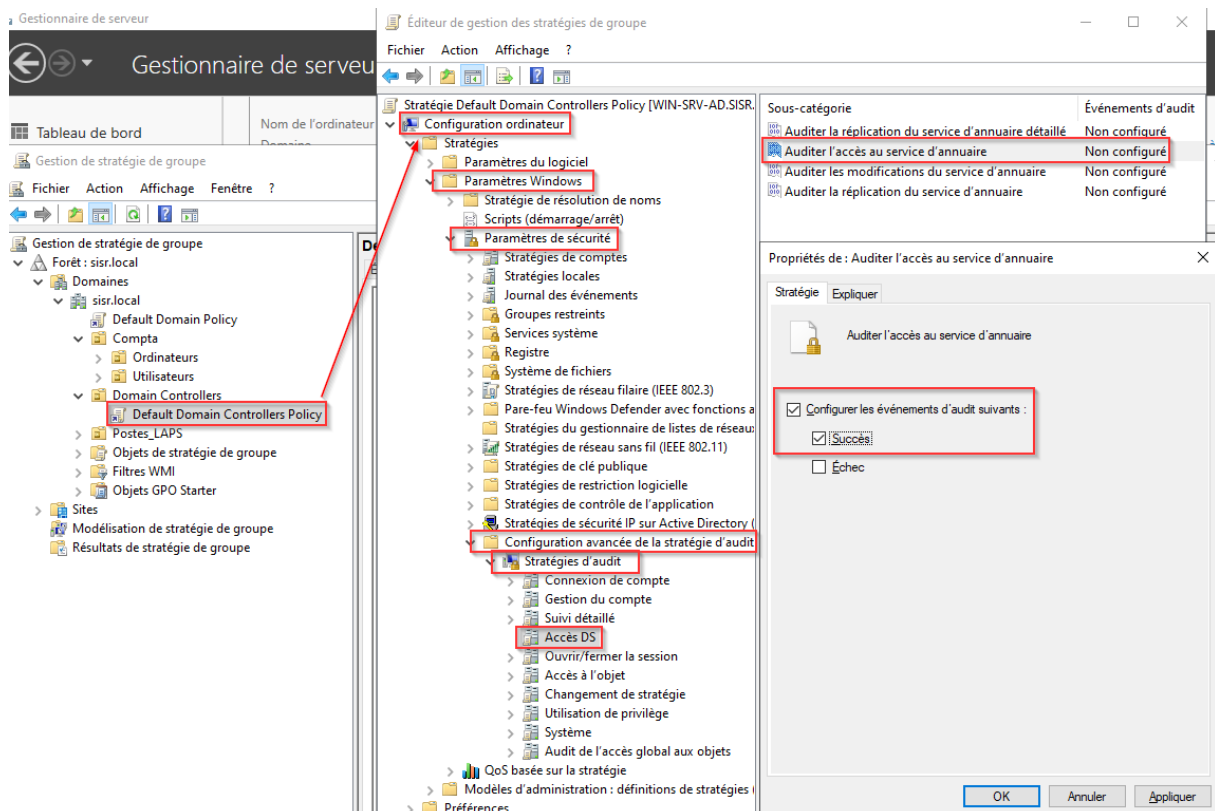
Mission SOC 1 : "Qui surveille les gardiens ?" (Audit de l'Event ID 4662)

L'objectif pédagogique : Faire comprendre la différence entre "sécuriser" et "surveiller". LAPS sécurise le mot de passe, mais si un administrateur se fait pirater son compte (ou agit avec malveillance) et lit les mots de passe de tous les PC de la direction, il n'y aura aucune trace. Par défaut, Active Directory ne journalise pas la "lecture" des informations pour ne pas saturer les disques durs.

Étape A : Allumer la caméra (La GPO d'Audit)

Il faut d'abord dire au serveur Active Directory d'activer la surveillance globale des accès aux objets (DS Access).

1. Sur le Contrôleur de Domaine, ouvrez la *Gestion de stratégie de groupe* puis cherchez dans l'arborescence le dossier *Domain Controllers*.
2. Faites un clic droit sur la **Default Domain Controllers Policy** et choisissez *Modifier*.
3. Naviguez dans : Configuration ordinateur > Stratégies > Paramètres Windows > Paramètres de sécurité > Configuration avancée de la politique d'audit > Stratégies d'audit > Accès DS.
4. Double-cliquez sur **Auditer l'accès au service d'annuaire**.
5. Cochez la case **Configurer les événements d'audit suivants : Succès**. (On veut savoir quand quelqu'un réussit à lire l'info).

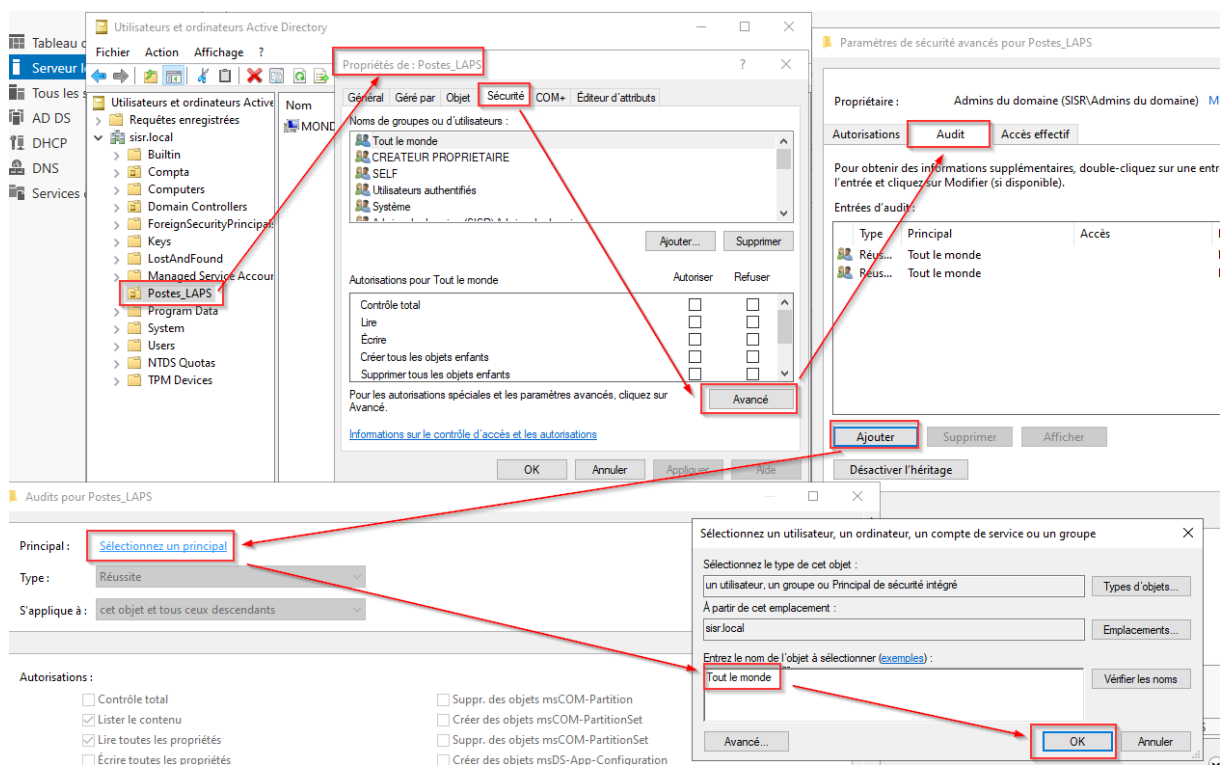


6. Fermez l'éditeur et tapez `gpupdate /force` sur le serveur.

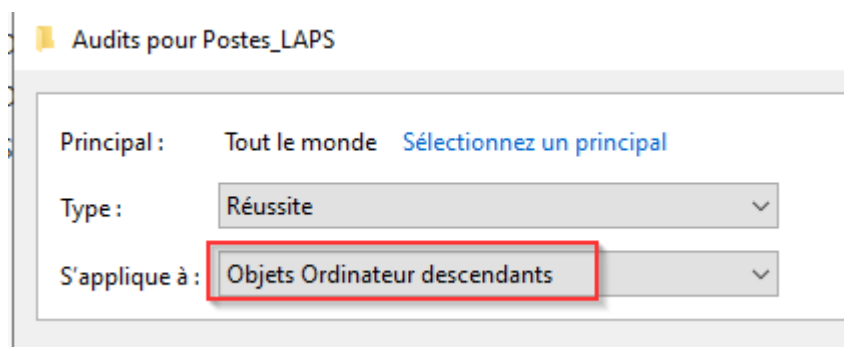
Étape B : Pointer la caméra sur la bonne cible (La SACL)

La caméra est allumée, mais elle ne regarde rien de précis. On va lui dire de filmer uniquement le dossier "Postes_LAPS".

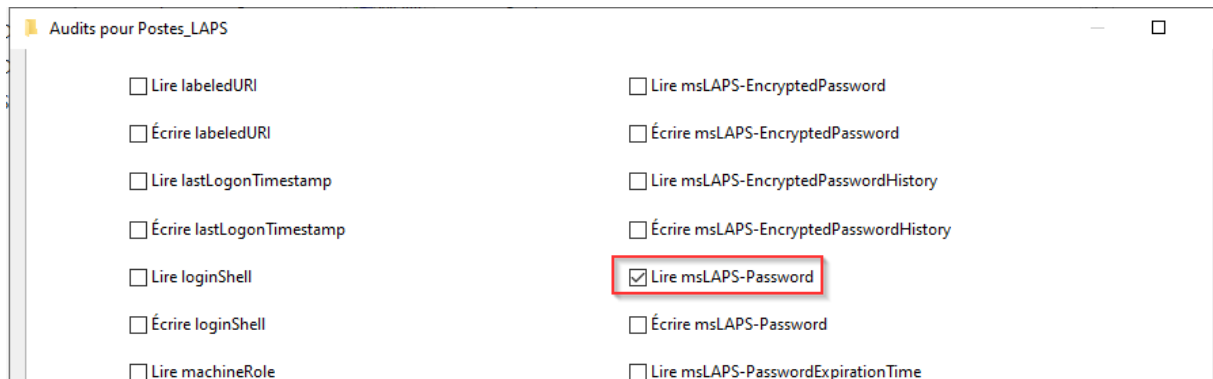
1. Ouvrez *Utilisateurs et ordinateurs Active Directory*.
2. Allez dans le menu **Affichage** et activez **Fonctionnalités avancées**.
3. Faites un clic droit sur l'OU **Postes_LAPS** > **Propriétés**.
4. Allez dans l'onglet **Sécurité** > cliquez sur **Avancé**.
5. Allez dans le tout dernier onglet nommé **Audit** et cliquez sur **Ajouter**.
6. **Principal** : Tapez *Tout le monde* (ou *Admins du domaine*).



7. **S'applique à** : Choisissez *Objets Ordinateur descendants* (On veut surveiller les PC dans ce dossier).



8. Dans la liste des autorisations tout en bas, cherchez et cochez **Lecture msLAPS-Password**. Cliquez sur OK partout.



Étape C : Le Test et l'Analyse (La Victoire du SOC)

1. La simulation de l'attaque :

Ouvrez PowerShell et lisez volontairement le mot de passe d'une machine :

```
Get-LapsADPassword -Identity "NOM_PC_CLIENT" -AsPlainText
```

2. La traque dans les logs :

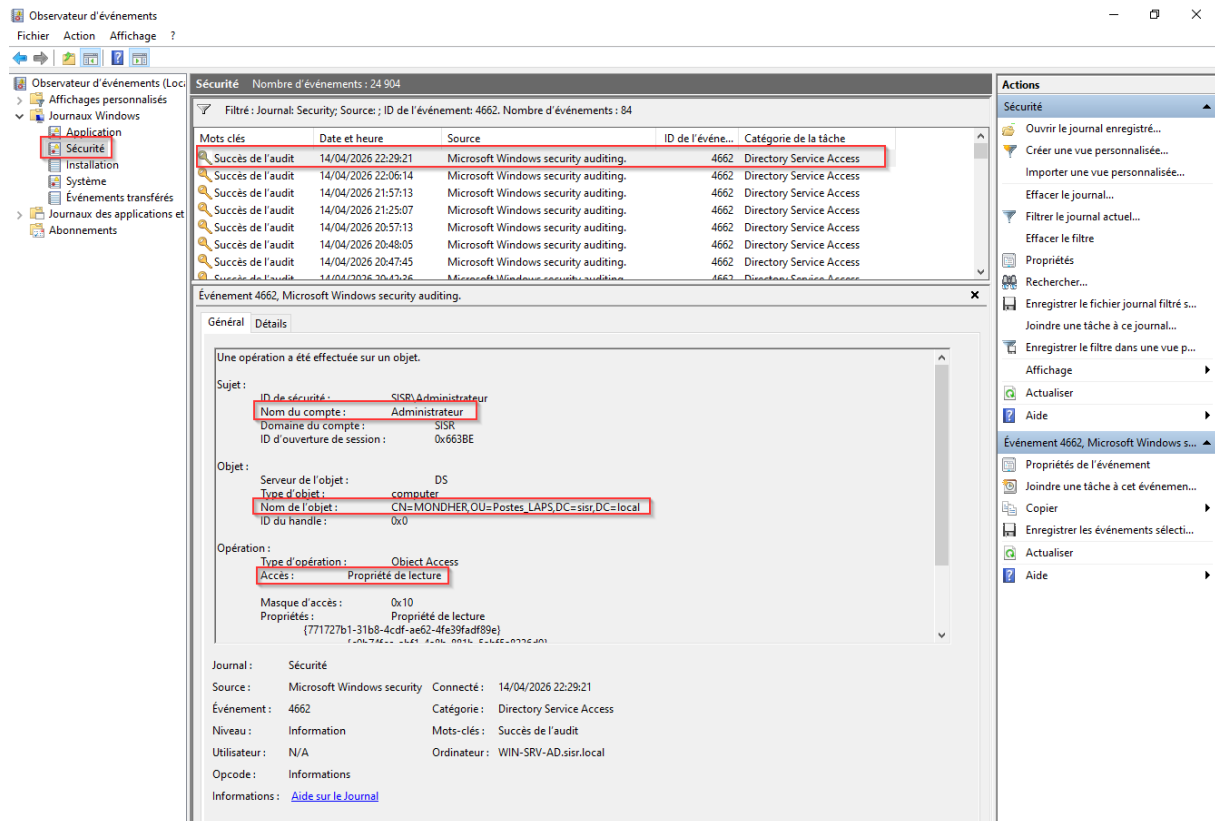
Ouvrez l'**Observateur d'événements** du serveur. Allez dans *Journaux Windows > Sécurité*.

Utilisez la fonction "*Filtrer le journal actuel...*" sur la droite, et tapez l'ID **4662**.

Ouvrez le premier événement trouvé. Vous devez y voir :

- **Nom du compte** : Le nom de l'administrateur qui a tapé la commande.
- **Nom de l'objet** : L'ordinateur ciblé (ex: CN=MONDHER).
- **Accès** : Lecture de la propriété (Read Property).

Déploiement et audit de Windows LAPS



Conclusion : Vous pouvez désormais configurer une alarme (SIEM / Wazuh) qui vous enverra un mail rouge clignotant à chaque fois que l'Event 4662 se déclenche sur un objet ordinateur critique !

Mission SOC 2 : Le technicien rebelle (Désynchronisation et Remédiation)

L'objectif pédagogique : Le "Split-Brain" (Cerveau scindé). Comprendre que l'ordinateur et le serveur sont deux entités distinctes. Si la réalité locale de l'ordinateur est modifiée de force, la base de données du serveur devient fausse et dangereuse.

Étape A : Le Sabotage (Le problème)

Un technicien intervient physiquement sur le PC. Il n'aime pas le mot de passe complexe de LAPS et décide de le changer pour se simplifier la vie.

1. Allez sur le client Windows 10/11.
2. Ouvrez une invite de commande (CMD) en tant qu'administrateur.
3. Tapez la commande suivante pour écraser le mot de passe local :

```
net user Administrateur MonMotDePasseFacile123!
```

4. Fermez la session et reconnectez-vous avec *MonMotDePasseFacile123!*. Ça fonctionne, le technicien a gagné.

Étape B : Le constat (Le danger)

Retournez sur le serveur Active Directory.

1. Tapez `Get-LapsADPassword -Identity "PC_CLIENT" -AsPlainText`
2. Le mot de passe affiché est-il le nouveau ou l'ancien ?

Réponse : C'est l'ancien ! L'Active Directory n'est pas au courant du sabotage. Si un autre technicien essaie de se connecter à distance ce soir avec le mot de passe de l'AD, il sera bloqué (Accès refusé).

Étape C : La Remédiation (Reprendre le contrôle)

En tant qu'Admin système, vous avez détecté cette anomalie. Vous devez obliger le PC à se conformer à la politique de l'entreprise et à générer un nouveau mot de passe aléatoire de 15 caractères sur-le-champ.

1. Sur le serveur, tapez la commande d'urgence qui réinitialise la date d'expiration du mot de passe LAPS à "Maintenant" :

```
Reset-LapsPassword -Identity "PC_CLIENT"
```

2. Allez sur le poste client.
3. Forcez la mise à jour des stratégies : `gpupdate /force`
4. Fermez la session du client. Essayez de vous connecter avec *MonMotDePasseFacile123!*. **Le mot de passe facile a été détruit et remplacé par LAPS !**

Conclusion : L'Active Directory a toujours le dernier mot, à condition qu'on lui ordonne de vérifier. Une bonne pratique consiste à forcer la rotation des mots de passe LAPS (`Reset-LapsPassword`) dès qu'un technicien a terminé une intervention physique sur une machine.